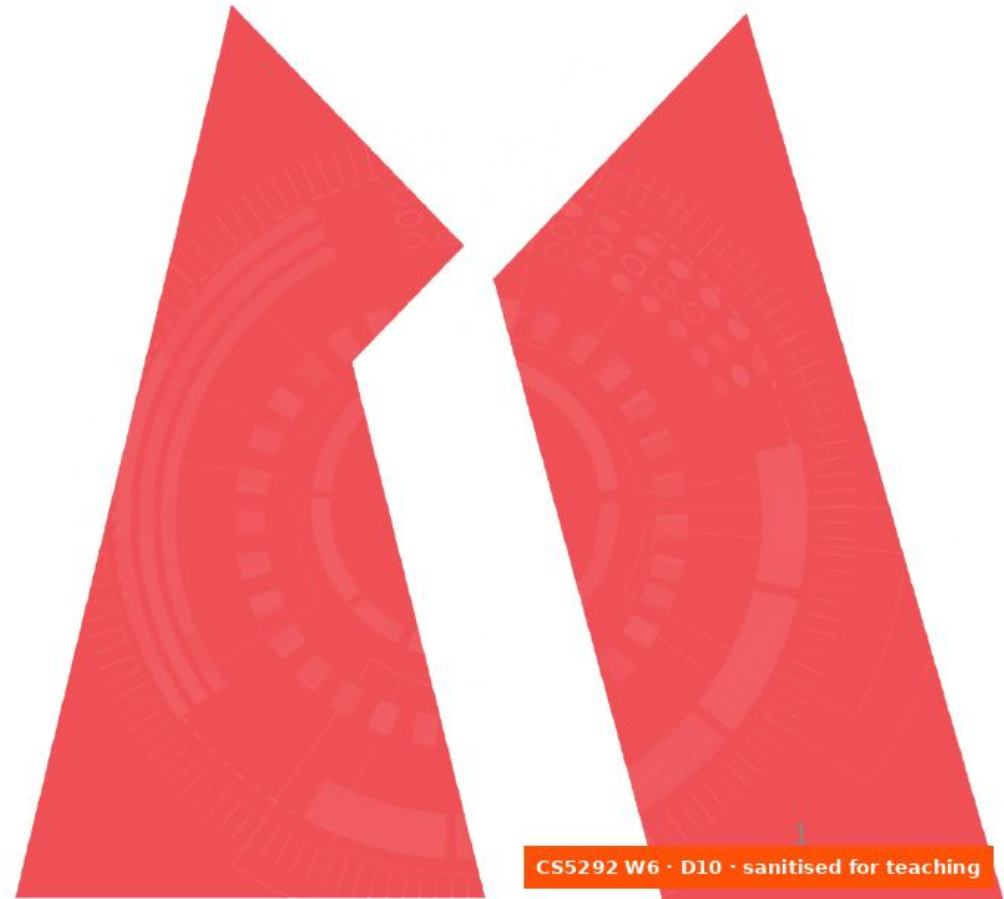
CYBER SECURITY Steering Committee

(CSSC 28-11-2025)



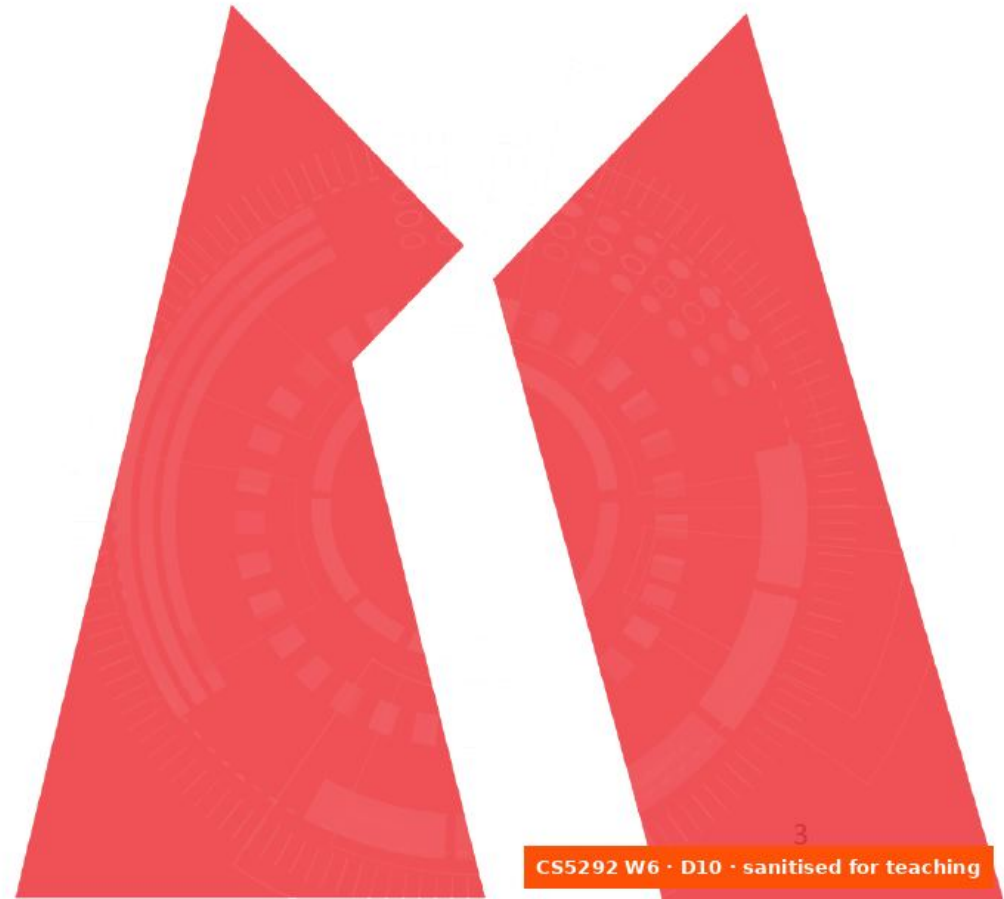
AGENDA

	AGENDA	Time Allocations	PRESENTER(S)
01	Introduction & clarification on the pre-read	3 Minutes	Chair
02	Update on Previous Action Items	5 Minutes	P-A
03	Cybersecurity Performance Metrics	5 Minutes	P-A
04	Emerging Threat Overview	15 Minutes	P-A
05	Summary of Incidents	10 Minutes	P-A
06	Journey through Maturity	10 Minutes	P-C/P-B/P-A
07	Data Protection and Cyber Risk Grid	10 Minutes	P-B/P-A
08	Open Discussion and Q&A	10 Minutes	

XYZ | XYZ Only

CS5292 W6 · D10 · sanitised for teaching

Update on Previous Action Items



XYZ | XYZ Only

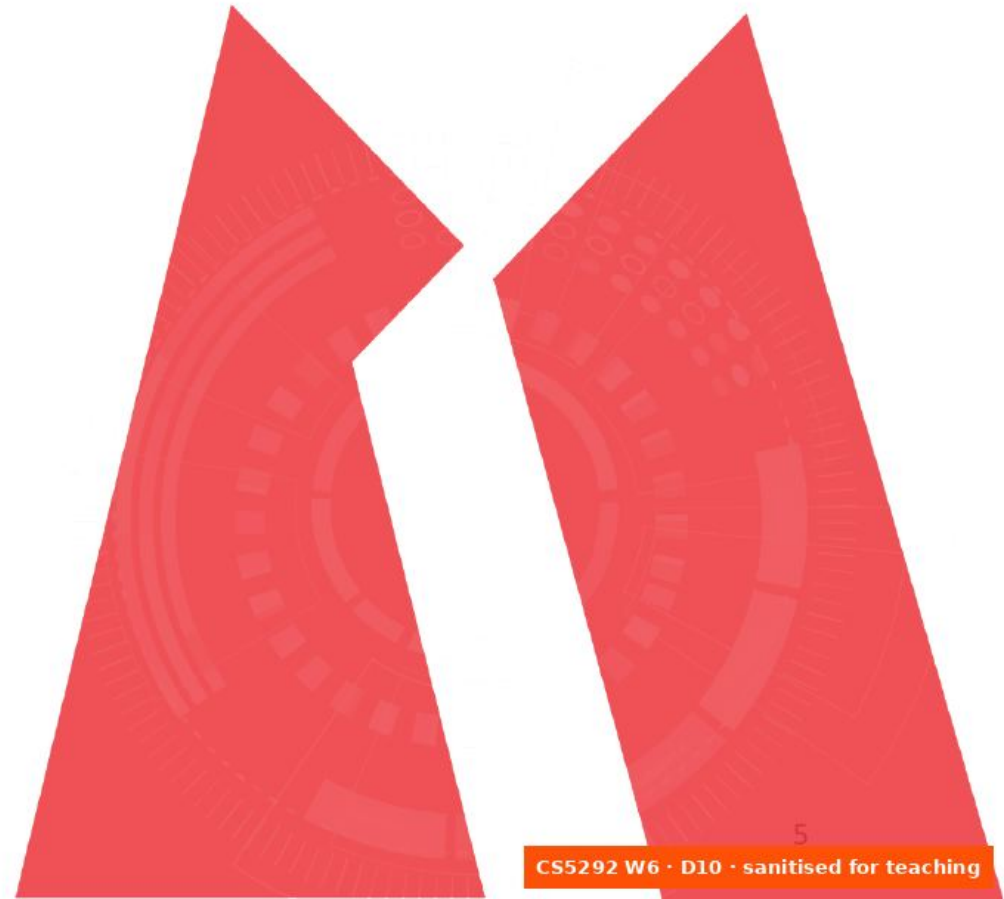
Previous Action Items

Actions Discussed	Responsible	Due	Actions Taken	Status
Share the AI policy with Group Legal for feedback	P-A	**19 June 2025**	**AI Policy shared with legal and feedback incorporated into the policy**	**Completed**
Incorperate definition of technology into the TOR of GTRC	P-A	**19 June 2025**	**Incorporated**	**Completed**

XYZ | XYZ Only

Cyber Security

Performance Metrics



XYZ | XYZ Only

Cybersecurity KPIs Q4 2025

SOC Detections Q4 2025	Priority	Q3 (2025)	Q4 (2025)	SLA	
Mean Time to Respond (by MSSP)	P1	-	-	15 mins	⬇
	P2	-	-	30 mins	
	P3	-	-	60 mins	
	P4	48 mins	42 mins	120 mins	
Mean Time to Respond (by XYZ SOC)	P1	-	-	15 mins	⬆
	P2	-	-	30 mins	
	P3	-	-	45 mins	
	P4	352 mins	390 mins	60 mins	
Mean Time to Resolve (MTTR)	P1	-	-	4 Hrs	⬇
	P2	-	-	24 Hrs	
	P3	-	-	5 Days	
	P4	1.5 Days	0.73 Days	14 Days	

* From 2025, Sources of Incidents: SIEM, EDR & TI

* The industry standard for **Mean Time to Respond** in cybersecurity benchmark is around 24 hour

* Average Organizations typically have a Mean **Time to Resolve** ranging from 24 to 72 hours.

Patching Compliance:

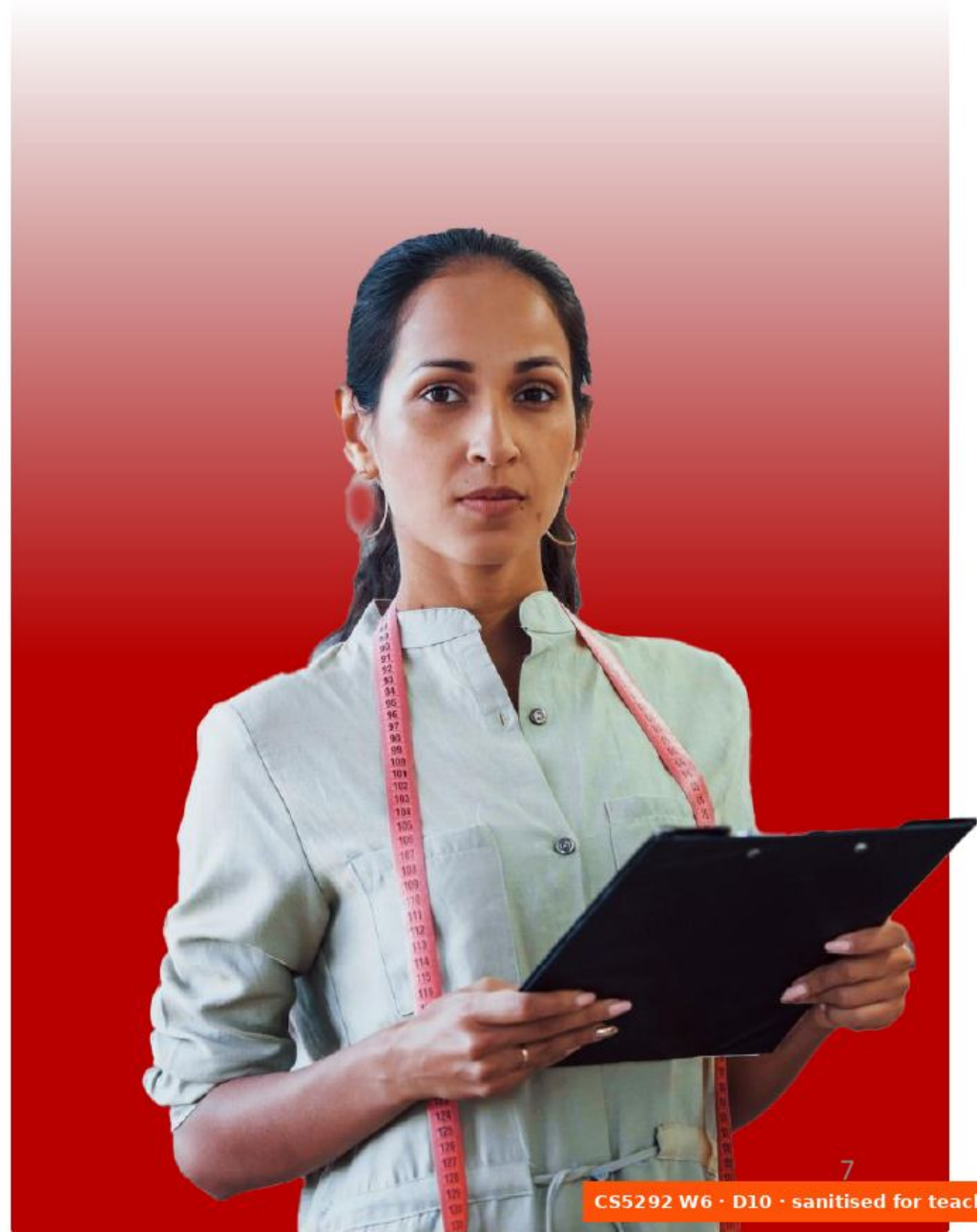
Windows Device Compliance	N	N-1	End of Support
End Device	80.02%	13.79%	⬆ 7.22%
Servers		99.00%	11.0%

Detection Count:

Quarter	P1	P2	P3	P4
Q3 (2025)	-	-	-	1260
Q4 (2025)	-	-	-	601

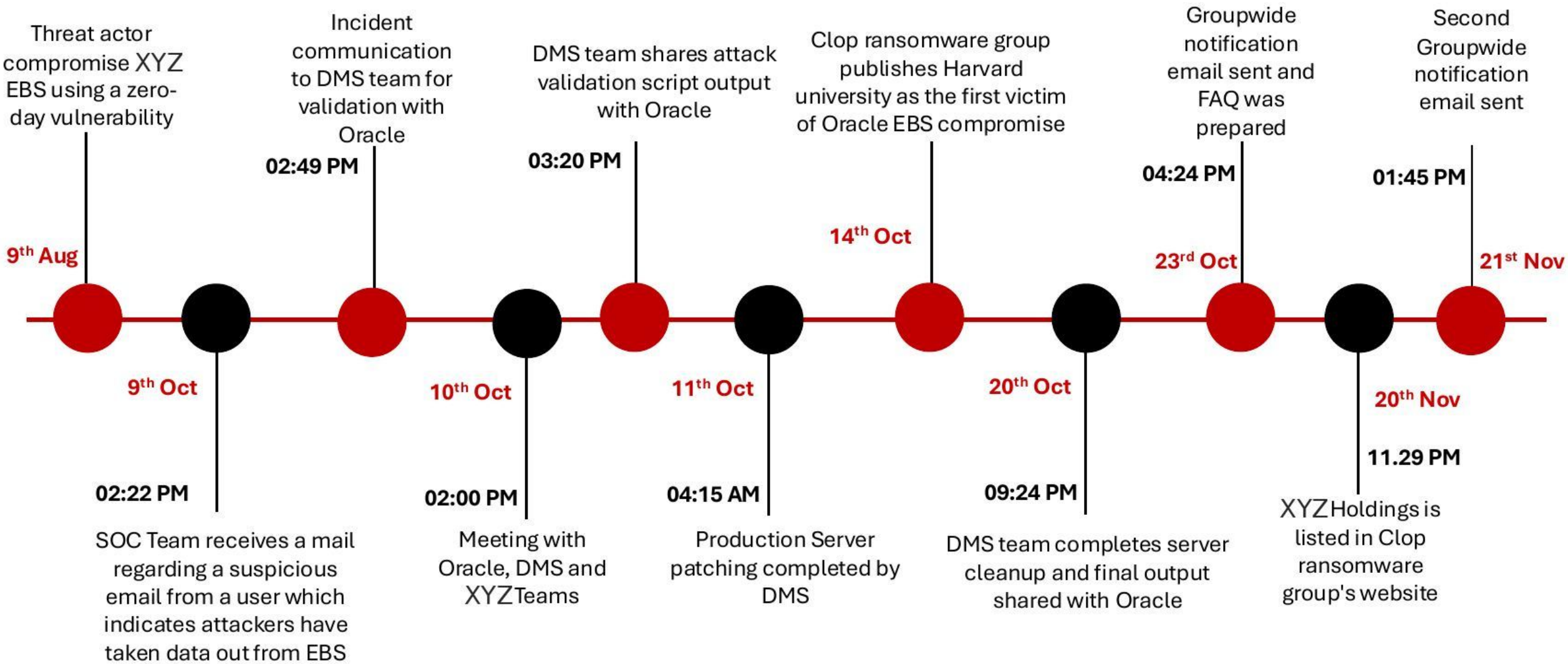
XYZ | XYZ Only

Summary of Incidents



XYZ | XYZ Only

Oracle EBS Incident



xyz | xyz Only

Oracle EBS Incident

Incident

"Cl0p" ransomware group used a previously unknown vulnerability in E-business suite to gain access to Oracle EBS systems worldwide and exfiltrated data out of the compromised environments. XYZ EBS environment was also compromised during the attack.

Required Actions

- Network level restrictions to be enforced reducing the exposed attack surface of the EBS environment.
- Agreement should be evaluated and amended to reflect security requirements and responsibilities.

Actions Taken

- Vulnerability which allowed the attackers access was patched.
- Affected servers were cleaned with the support from Oracle.
- CrowdStrike EDR was deployed to the EBS environment.

Root Cause

Lack of clear security requirements and security responsibility segregation to supplier led to the EBS environment function without proper security tools, monitoring and hardening practices which allowed the attackers to exploit the vulnerability and exfiltrate data.

xyz | xyz Only

Cyber Security Emerging Threat Overview



XYZ | XYZ Only

Emerging Threat Overview

Generative AI (GenAI) Risks



AI-driven attacks are accelerating, attackers use LLMs to generate malware, obfuscate code, and craft phishing campaigns at scale. 1 in every 44 GenAI prompts in enterprise networks posed a high risk of sensitive data leakage. 87% of organizations using GenAI tools were impacted.

Organizational Response

- Finalized the AI Policy to address GenAI-related risks.
- Initiated implementation of a Cloud Access Security Broker (CASB) platform this quarter.

Recent Attacks

- Claude Code used in large scale extortion operation

Ransomware & Supply Chain Exploits



Ransomware remains the dominant threat, with LockBit 5.0, VanHelsing, and Cl0p leading campaign. platforms like Lockverse have industrialized attacks, offering subscription models and dashboards for affiliates. Average ransom demands rose 32% YoY, reaching $4.2M per incident. Manufacturing and logistics sectors were hardest hit

Organizational Response

- Supplier security assessment.
- Security hardening and patch management automation

Recent Attacks

- Cl0p Oracle EBS zero-day campaign MOVEit-style breaches.
- Salesforce Data Breach

SaaS & Cloud Security Risks



As organizations increasingly adopt SaaS applications and cloud services, misconfigurations, weak identity controls, and insecure APIs have become major attack vectors. Threat actors exploit these gaps to gain unauthorized access, exfiltrate sensitive data, and launch lateral attacks across interconnected cloud environments.

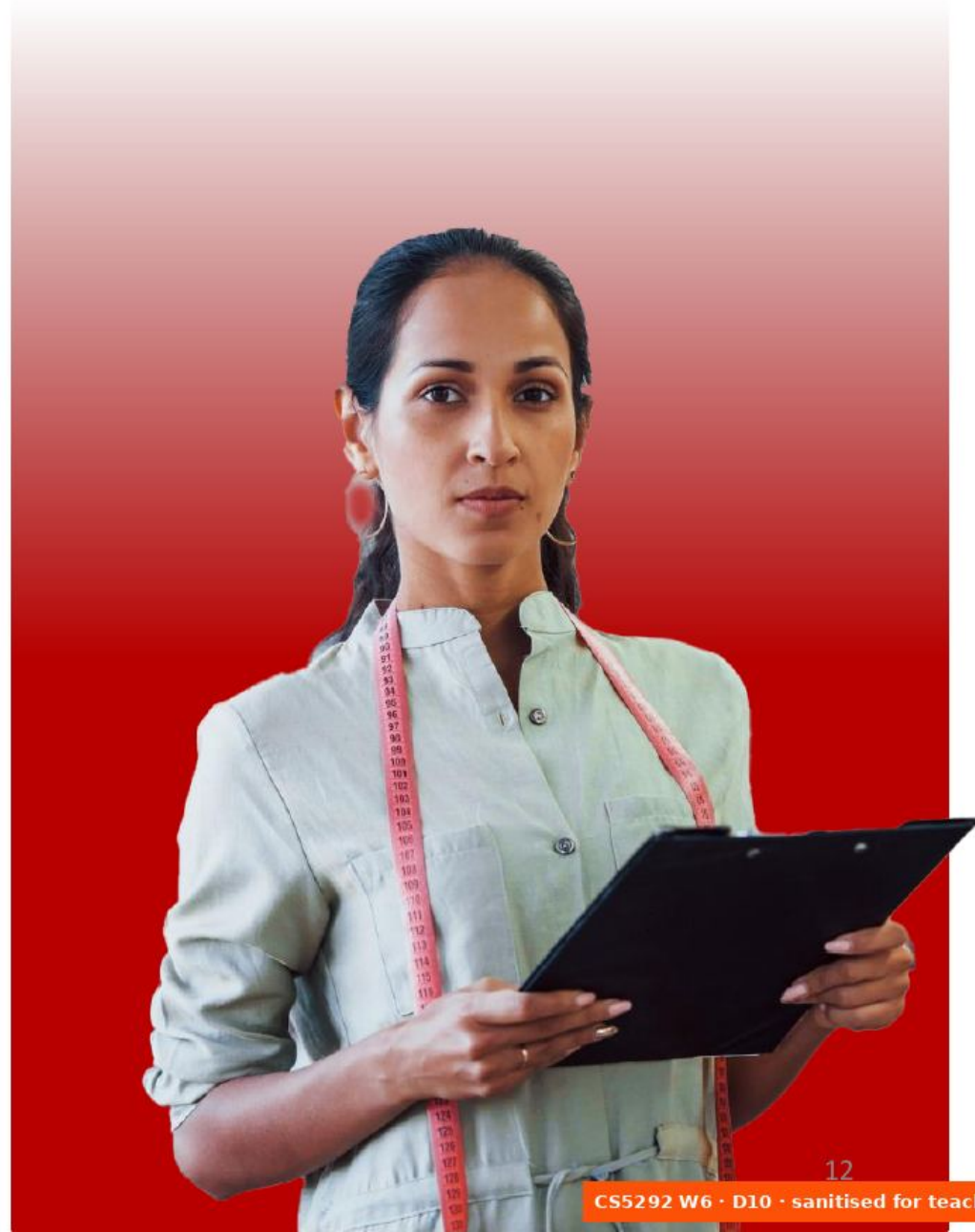
Organizational Response

- CSPM Implementation
- Launch of SaaS Security Posture Management (SSPM) project planned for Q2 2026.

Recent Attacks

- Snowflake data breach

Journey Through Maturity



XYZ | XYZ Only

Attack Surface Reduction

Azure Web sites	9 Apps decommissioned 179 Apps Restricted 35 Apps without Restrictions
Imperva WAF	5 Apps decommissioned 91 Apps Restricted 31 Apps without Restrictions
Applications	1675 applications blocked out of total 5070 Applications

400+ Applications Blocked through CrowdStrike

1200+ Applications Removed through Autopilot Deployment

As part of the Attack Surface Reduction initiative, XYZ webapps access was **restricted to** XYZ **and Zscaler IP ranges**, and over 1600 end point applications have been disabled. This will strengthen the cybersecurity posture by minimizing exposure to threats, enhancing compliance with security standards, and reducing the overall digital risk footprint.

Attack Surface Reduction

Azure Web Apps Not Restricted

7	Centurm
4	Enadoc
4	Routing Flexibility
3	Oracle Middleware - Production
2	Oracle Middleware - Development
2	Shopfloor Dashboard

The following Azure web applications are exempt from XYZ and Zscaler IP restrictions as per business requirements.

Application	# of Web Apps
Data ARK AuthApp 2.0	1
one.xyzholdings.com	1
E-Invoice	1
DivisionQuality App	1
Sub assembly system-PRD	1
Centric PLM - Development	1
KREEDA Cutting Scheduler-Development	1
Shopfloor Dashboard - Development	1
Kreeda IoT device Integration to Azure Iot	1
SYNDIGI App	1
XYZ Life web	1
MDS_Division-I_Central Data Analytics	1

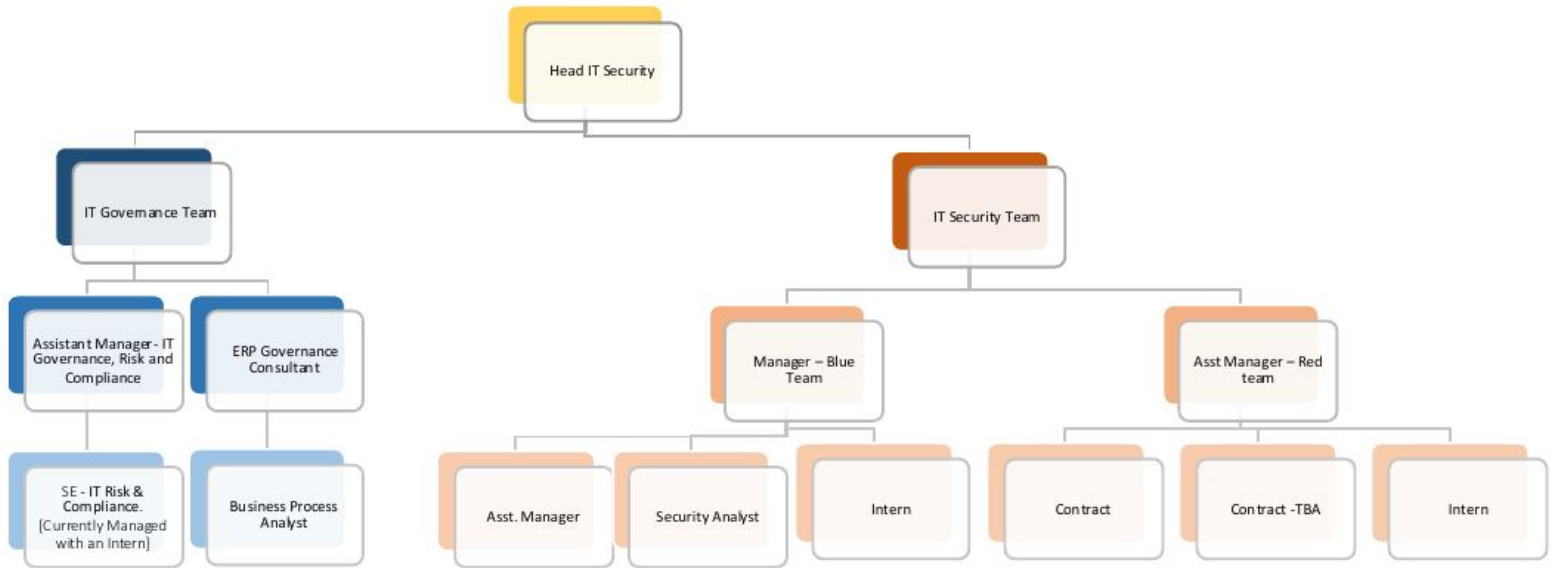
Walkthrough of ISMS Online Platforms and How to Track Risks

- 12_Usage of outdated operating systems allowing vulnerabilities to be open in XYZ environment
- 16_Public Exposure of Web Applications with Inadequate Access Controls - Azure
- 12_Public Exposure of Web Applications with Inadequate Access Controls - WAF
- 16_Lack of employee awareness leading to cyber security Incidents
- 16_Data Leakage through unmanaged IT assets - Mobile Phones
- 12_Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported end devices leading to system downtime - Laptops/ Tabs/ Embedded Devices
- 12_Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ- Sub-A / XYZ Sub-B USA / Sub-C
- 12_Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business systems

Governance & Security Structure

Manage risk and standardize

IT GOVERNANCE TEAM
- Governance direction
- Risk Management
- Audit & Compliance Management
- Policy Management
- Identity and Access Design and change (IAM)
- Vendor Risk Management
- Business Impact Assessment (BIA)
- Alignment with ISO 27001
- Security Awareness Training



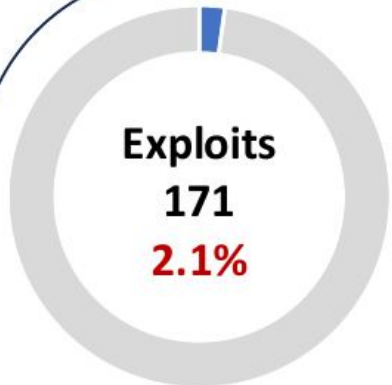
Defend and Respond

BLUE TEAM
- Security Operations
- Cloud Security
- Incident Response
- Endpoint Security
- Container Security
- Threat Intelligence
- Secure Configuration
- Database Security

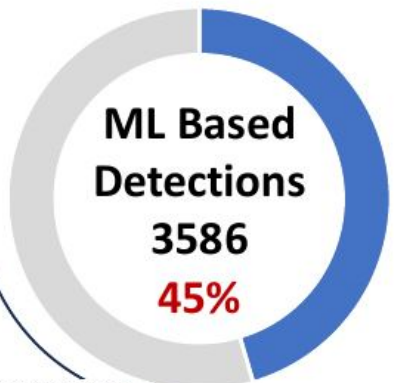
RED TEAM
- Penetration Testing and red team assessment
- Vulnerability and Patch Management
- IT and third party risk assessment
- IoT Security
- Web/Mobile Application Security
- API Security
- Secure Software Development Lifecycle (SDLC)
- Secure Coding Standards and Guidelines
- Web Application Firewall (WAF)
- Security Assessment
- Email Security
- Test defenses and identify gaps

Security Performance

Endpoint Detection and Response (EDR)







Total Detections (Last 90 Days)

7,889

Escalated	After Hours
189	89

Other Detections

- Impact 49
- Malware 40
- Execution 18
- Defense Evasion 15

Security Information and Event Management (SIEM)







Total Detections (Last 90 Days)

42,338

Escalated	After Hours
109	51

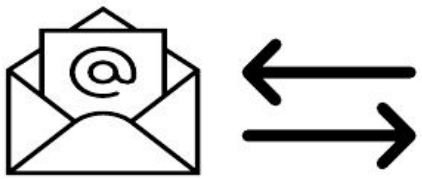
Other Detections

- Credential Access 786
- Persistence 272
- Execution 507

XYZ | XYZ Only

Security Performance

Email Security



302,865 Detections

For Last 90 Days

Spam Mails	294,273
Phishing	5,609
Malware	2,831
Blocked URL Clicks	357
Blocked Attachments	200

Open Critical and high vulnerabilities includes EOS servers planned for upgrades in 2026, 3rd party applications and support components which have dependency with running application which require time for planning, testing and rolling out infra and DE already working together on fix.

Critical(Open) : 4931

Critical(Fixed) : 2166

High(Open) : 18973

High(Fixed) : 8551

34,621 Vulnerabilities

As of End of Q3

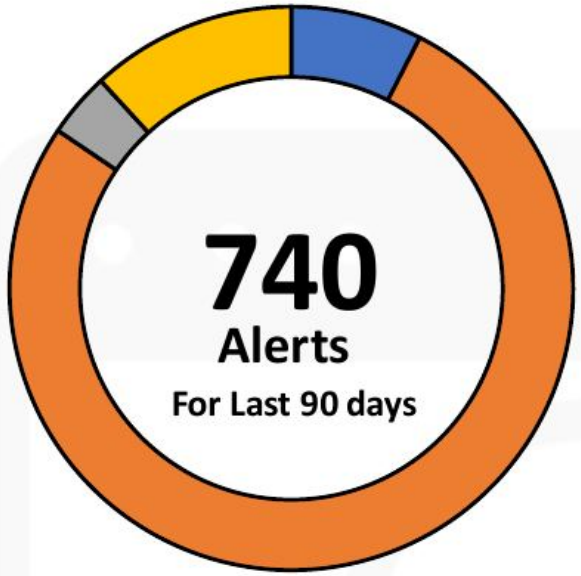


Vulnerability Management

XYZ | XYZ Only

Security Performance

Extended Threat Intelligence Platform



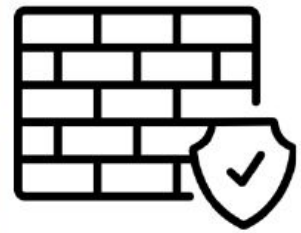
- Brand Protection
- Darkweb monitoring
- Inventory monitoring
- Op Intelligence

Stolen Credentials On Dark Web Bot Market	176
Supply Chain Attacks	163
Impersonating Domain	130
Vulnerability Intelligence	77

Firewalls

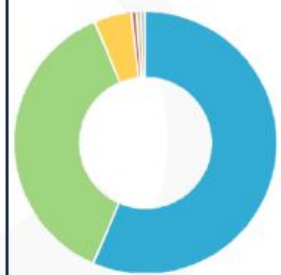
120,175,089 Blocked Traffic → Palo Alto Firewall

3,592,288,341 Blocked Traffic → FortiGate Firewall



For Last 90 days*

Zscaler



- Adware/Spyware Sites
- Malicious Content
- Phishing
- Web Spam
- Suspicious Destination

69,100
Detections
For Last 90 days

Web Application Firewall



For Last 90 days

Traffic From Blocked IPs	506,200
Cross Site Scripting	54,800
Blocked Country	19,700
Illegal resource Access	7,300
SQL Injection	2,800

CS5292 W6 · D10 · sanitised for teaching

Device Compliance

CrowdStrike (CS) Coverage 99.77%

CS Coverage	Count
Covered	15854
Not Covered	36

Intune Deployment Issue – 2
Not Installed – 20
Non-Domain - 11
Excluded - 3

ZScaler (ZS) Coverage 99.19%

ZS Coverage	Count
Covered	15762
Not Covered	128

Sub-C is still not under XYZ domain, so Zscaler cannot be used in those devices. – 108
Intune deployment Issue - 6
Non-Domain – 11
Excluded - 3

Outdated OS

OS	Count
Microsoft Windows 8.1	7
Microsoft Windows 7	4
Linux	29

Qualys Coverage 100%

Qualys Coverage	Count
Covered	770

Upcoming Projects

Business Impact Assessment (BIA)	Ensure business continuity and resilience while aiming to reduce the downtime risk. Will include consultancy-led impact assessments, define recovery priorities and tolerances and develop continuity and disaster recovery plans.
ISMS (Information Security Management System)	Systematically protect the confidentiality, integrity, and availability of information by managing risks through policies, processes, and continuous improvement.
CASB Implementation	Provide enhanced visibility and control over cloud application usage, improved data security, and compliance enforcement across SaaS environments.
Cyber Security Maturity Assessment	Provided an assessment of current capabilities, identified gaps, and deliver actionable recommendations to strengthen security posture and align with industry best practices

Data Protection and Cyber Risk Grid

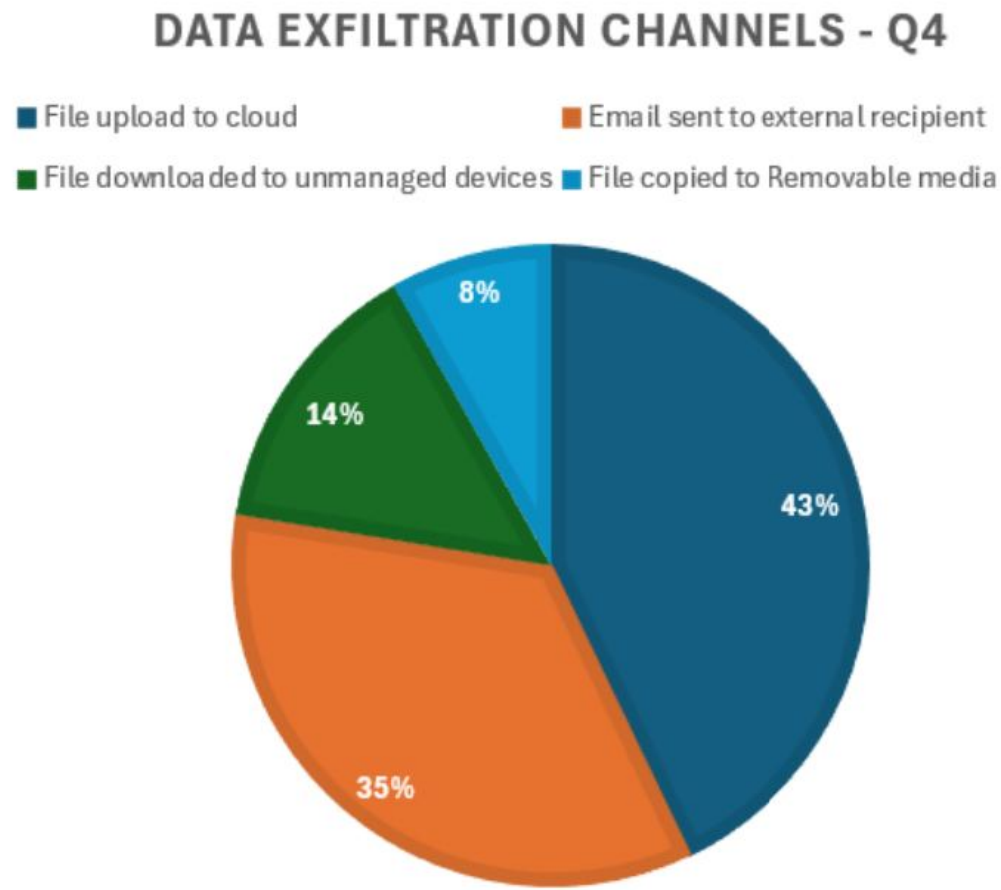


DLP Statistics

Critical Alerts Investigated in Q4 2025

Status	#
Closed	25
Inquiry in progress*	24
Total	49

*Open incidents are pending user or line manager response





XYZ | XYZ Only

CS5292 W6 · D10 · sanitised for teaching

Vulnerabilities in Core Systems

As of Report Generated on 11/24/2025

Application	Critical - Q3(Active)	Critical - Q3(Fixed)	High - Q3(Active)	High – Q3(Fixed)	Percentage Fixed
SAP Unit-3	40	0	55	2	2%
SAP Unit-2	72	5	138	12	7%
SAP Unit-4	22	0	26	1	2%
SAP Unit-1	20	0	27	1	2%
Unit-5SAP	1	6	8	8	61%
Shopfloor	46	23	89	37	31%
Idea PLM	7	9	33	39	55%
GSD	6	13	56	41	47%
Bank Intergration	28	6	51	25	28%
App-R	21	3	27	14	26%
Non SAP - Production App DBs	3	4	14	16	54%
Fastreact	49	22	255	116	31%
Darwin	11	47	45	79	69%
ECC Cloud connector	1	6	22	14	47%
KoFax	12	36	43	218	82%
E Transport	2	1	5	13	67%
Unit-2ye system	0	2	13	8	43%

*Active – Open vulnerability cou

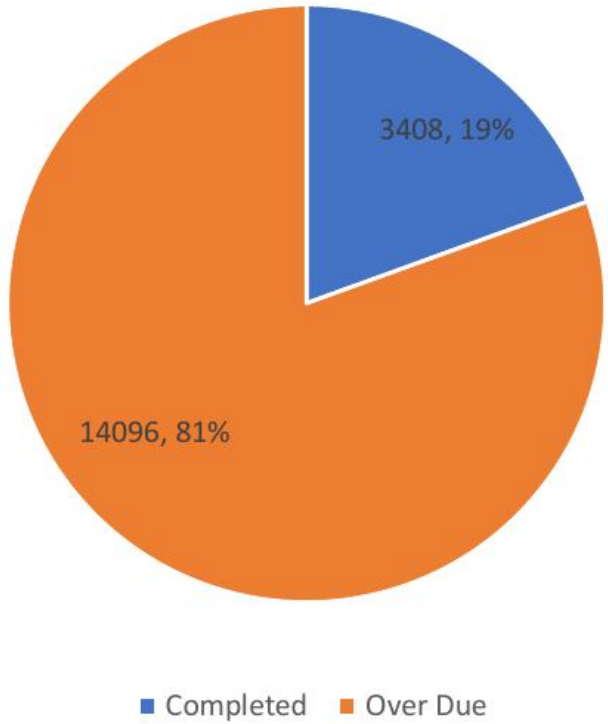
XYZ | XYZ Only

CS5292 W6 · D10 · sanitised for teaching

Mimecast Engage Q4, 2025

Completed nearly 20% of user security awareness trainings. Continued push underway to close remaining gaps and uplift overall cyber security awareness.

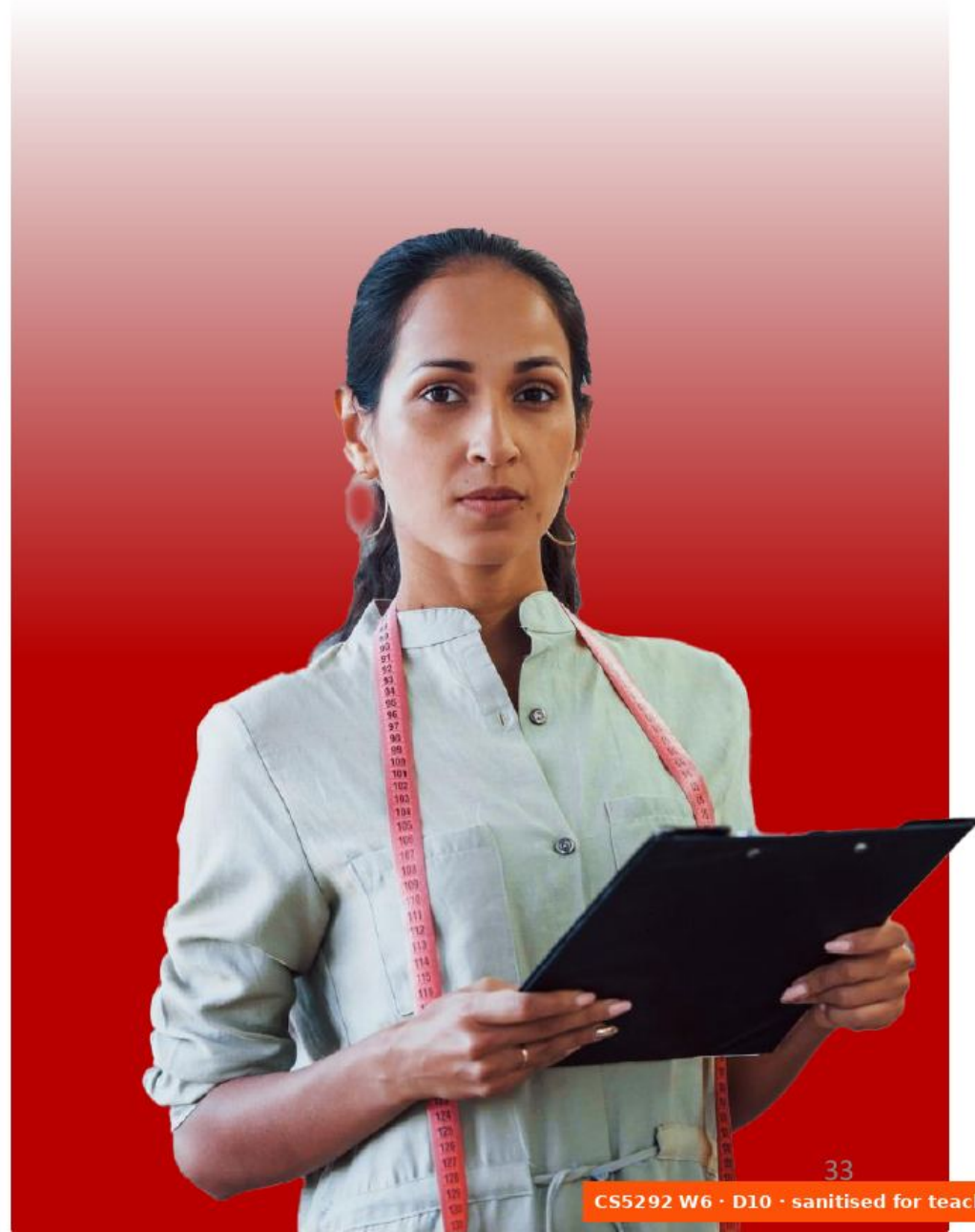




Actions:

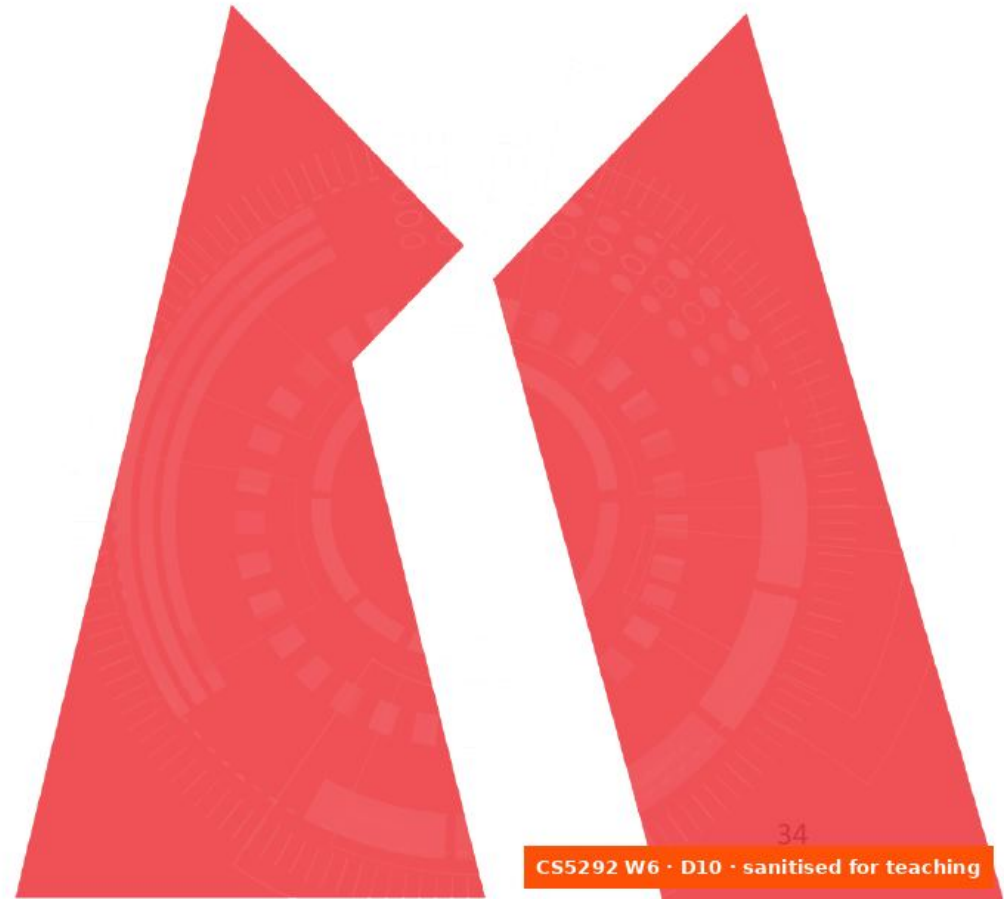
- Reminder scheduled from Mimecast for training overdue users once a week.
- Discussing about sending weekly or Bi-weekly reports to department heads accelerate training completion rate.

Open Discussion and Q&A



XYZ | XYZ Only

APPENDIX



XYZ | XYZ Only

Pre-read

Cyber Risk Grid – Key Risk Indicators (Q4, 2025)

#	Headline Risk	KRI
1.	Risk of an attack by a cyber criminal due to lack of employee awareness.	Include phishing simulation tracker with victim out of total users Reduction Plan <10% click rate - Likely <5% click rate - Possible <3% click rate - Unlikely
2.	Risk of an attack by a cyber criminal as result of using unpatched /vulnerable/End of Life/End of Support software's and/or applications and/or EOL Hardware devices	Reduction Plan - (end devices 88%, servers 75%) - Almost Certain (end devices 86%, servers 82%) - Likely (end devices 95%, servers 90%) - Possible (end devices 100%, servers 100%) - Unlikely
3.	Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported systems devices leading to system downtime - Embedded Devices	Develop list of devices other than Workstations and Servers -> list and vendor patch release status
4.	Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ-Sub- / XYZ Sub-B USA / Sub-C	List of non-governed XYZ entities-> compliance level for security (Endpoint security, Email security, Internet security, Application security, Network Security) List of critical vendors->compliance level Self Assessment to be provided Self assessment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
5.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system (SAP) - For Unit-1/Matrix /Unit-2	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely

Cyber Risk Grid – Key Risk Indicators (Q4, 2025)

#	Headline Risk	KRI
6.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely
7.	Risk of a cyber security incident as a result of an attack by a cyber criminal as a result of a supply chain attack	List of critical vendors->compliance level Self Assessment to be provided Self assesment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
8.	Risk of a cyber security Incident as a result of an unmanaged IT Asset within XYZ Infrastructure. Unmanaged Server/Laptop /API Connection	A-% of devices deployed through intune B-% of local admin accounts detected C-% of browserware detected in CS IT hygiene Almost certain (A <80%, B<10%, C>300) Likely (A<90%, B<5%, C<300) Possible (A<95%, B<1%, C<100) Unlikely (A=100%, B=0, C<50)
9.	Risk of a cyber security incident as a result of Shadow IT	
10.	Risk of a Cyber security incident as a result of a device/system misconfiguration i.e. Misconfiguration in a AD Server or Perimeter firewall and/or System.	List of domain servers, firewall baseline configuration < 80% compliance - Almost certain <85% compliance - Likely <95% compliance - Possible 100% compliance - Unlikely
11.	Risk of a Cyber Security incident as a result of inadequate IT Asset Management Policy	A-% of devices enrolled through auto pilot B- % of devices enrolled through Intune C- Device lost case wipe average time Almost certain (A <80%, B<20%, C<5 days) Likely (A<90%, B<5%, C<3 days) Possible (A<95%, B<5%, C<2 days) Unlikely (A=100%, B=0, C<

Cyber Risk Grid – Key Risk Indicators (Q4, 2025)

#	Headline Risk	KRI
12.	Risk of a Cyber Security Incident as a result of a malware infection	A-Non-Deployment of CrowdStrike for XYZ assets B-Coverage of mailboxes through Mimecast A< 50 endpoints, B<95% - Almost certain A<30 endpoints, B<98% - Likely A<20 endpoints - Possible 100% compliant on CS, B<99.5 - Unlikely
13.	Risk of Cyber Security Incident as a result of activities of State Sponsored and/or nation state cyber criminals /cyber terrorists targeting XYZ Holdings	Number of threat intel incidents detected (numbers to be defined after setting up SOC radar process)
14.	Risk of a cyber security incident /intrusion as a result of lack of adherence to standard operating procedures within XYZ Technology Services.	

End of Pre-Read

Thank You

